Generation Chile

SEGURIDAD EN DESARROLLO WEB

- **Conceptos clave:**
  - **Vulnerabilidad:** Debilidad en el código o configuración.
  - **Intrusión:** Acceso no autorizado explotando una falla.

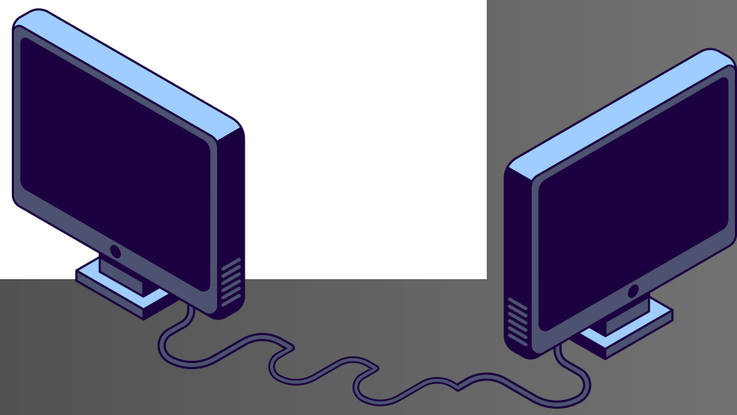
Riesgos: Robo de datos, daño reputacional y multas legales.

AUTENTICACIÓN VS. AUTORIZACIÓN

- Autenticación (¿Quién eres?): Verificación de identidad antes del acceso.
- Autorización (¿Qué puedes hacer?): Verificación de permisos y roles tras entrar al sistema.

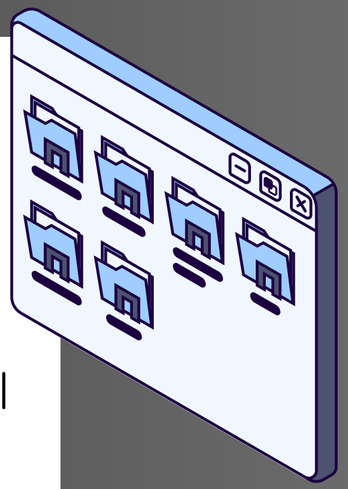
Diferencia técnica: La autenticación ocurre primero (login); la autorización determina el acceso a recursos específicos (roles admin/user).

- Estándares de seguridad: Mínimo 12 caracteres, uso de símbolos, números y evitar datos personales.
- Hashing: Transformación irreversible de la contraseña; el sistema nunca guarda el texto plano.
- Implementación en Java: Uso de BCryptPasswordEncoder para codificar y comparar credenciales.
- Prohibición: Nunca utilizar algoritmos obsoletos como MD5 o SHA1.



GESTIÓN SEGURA DE CONTRASEÑAS

VULNERABILIDADES CRÍTICAS EN EL CÓDIGOTICO

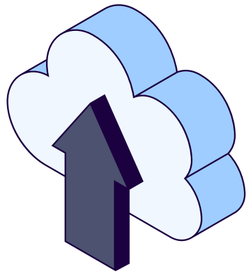


- SQL Injection: Inserción de código malicioso en formularios para manipular la base de datos.
- XSS (Cross-Site Scripting): Inyección de JavaScript que se ejecuta en el navegador de otros usuarios.
- Exposición de datos: Guardar tokens o información sensible sin cifrar o en texto plano.

Causa raíz: Confiar en los datos del usuario sin validar ni sanitizar.

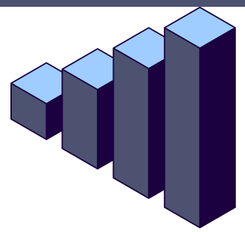
SEGURIDAD DE RED Y TRANSMISIÓN

HTTPS (HTTP + TLS/SSL)



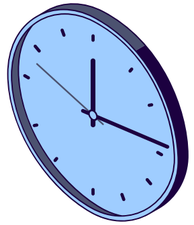
Cifra la comunicación para asegurar confidencialidad, integridad y autenticidad.

Riesgo (MitM)



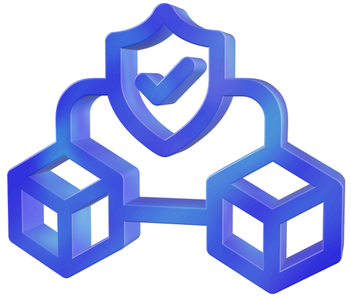
Sin HTTPS, los datos pueden ser interceptados en texto plano (ataques Man-in-the-Middle).

Firewall



Filtro de tráfico basado en reglas (IP, puertos o protocolos).

Rate Limiting



Protección contra ataques de fuerza bruta y saturación (DDoS)

- **Escenario:** Un usuario accede a un recurso (como una orden de compra) que no le pertenece.

- **Diagnóstico:** Fallo de autorización por confiar ciegamente en el ID enviado por el cliente.
-
- **La Solución en Java:**
  - Implementar control de acceso basado en roles (RBAC).
  - Validar siempre que el recurso pertenece al usuario autenticado en el backend.

CASO PRÁCTICO Y SOLUCIÓN DEVELOPER

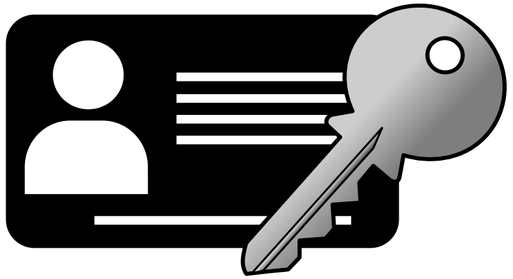
ANALOGÍA

Llave maestra

Password

Carnet y llaves de paso

Permissions



La ventana mal cerrada

Vulnerabilidad

El Robo en Progreso

Intrusión

BONUS

- ¿Qué es JWT (JSON Web Token)?: Es un token de autenticación que viaja firmado digitalmente para asegurar que no ha sido alterado. Permite que el servidor valide al usuario sin consultar la base de datos en cada petición.

- Autenticación con Tokens: El servidor genera un token firmado que el cliente guarda (localStorage o cookies). Es el modelo estándar para APIs REST y microservicios.

- Rate Limiting: Técnica que limita la cantidad de peticiones por usuario o IP para prevenir ataques de fuerza bruta y saturación del servidor (DDoS)